

Analyst Triage Guide

Windows Detection Engineering Lab — Wazuh, Sysmon & MITRE ATT&CK

Project: Windows Detection Engineering Lab — Wazuh, Sysmon & MITRE ATT&CK

Detection Scope: 5 validated detections

Environment: Local Windows detection engineering lab

Tools Used: Wazuh SIEM/XDR, Windows 10, Sysmon, Windows Security Logs, Windows Defender, Atomic Red Team, MITRE ATT&CK

1. Purpose of This Triage Guide

The purpose of this Analyst Triage Guide is to provide a structured SOC-style investigation process for each validated detection in the Windows Detection Engineering Lab. This document explains how a SOC analyst would review, investigate, validate, and escalate alerts generated by custom Wazuh detection rules.

This guide is designed to move the project beyond basic alert generation. Instead of only showing that Wazuh can generate alerts, this document explains how those alerts should be interpreted in a real security operations workflow. Each detection includes investigation questions, triage steps, key fields to review, false-positive considerations, escalation criteria, and recommended analyst actions.

The validated detections covered in this guide are:

Detection ID	Detection Name	Custom Rule ID	MITRE ATT&CK Technique
DET-001	PowerShell Encoded Command Execution	100100	T1059.001
DET-002	Local User Account Creation	100101	T1136.001
DET-003	Windows Service Creation / Modification	100102	T1543.003
DET-009	EICAR Malware-Test File Detection	100108	T1204.002

The guide assumes that the analyst is reviewing alerts inside Wazuh Dashboard and has access to alert details, JSON fields, host information, timestamps, event logs, and supporting screenshots or evidence.

2. General SOC Triage Methodology

Every alert should be investigated using a consistent triage process. A detection should not be treated as malicious only because it fired. The analyst must review the alert context, validate the activity, determine whether it is expected, and decide whether escalation is required.

The general triage workflow used in this project is:

Step	Triage Action	Purpose
1	Confirm the alert	Verify that the Wazuh rule fired correctly
2	Identify the affected host	Determine which endpoint generated the alert
3	Identify the user account	Determine which account performed the action
4	Review process or command-line details	Understand what was executed
5	Review event source	Confirm whether the event came from Sysmon, Security logs, or Defender
6	Map to MITRE ATT&CK	Understand the adversary behavior represented by the alert
7	Check surrounding activity	Look for related alerts before and after the event
8	Evaluate false positives	Determine whether the activity was expected or authorized
9	Decide severity	Classify the alert based on context and risk
10	Escalate, close, or document	Take the appropriate SOC action

A single alert may not always prove compromise. However, alerts become more serious when they appear with related suspicious activity. For example, PowerShell encoded command

execution followed by local account creation and service creation would be more concerning than each event appearing separately in a controlled lab environment.

3. General Questions for Every Alert

For every detection in this project, an analyst should begin with the following questions:

Question	Reason
Which endpoint generated the alert?	Identifies the affected asset
Which user account was involved?	Helps determine whether the action was authorized
What command, process, or event triggered the alert?	Explains the behavior
What telemetry source generated the event?	Confirms whether the data came from Sysmon, Security logs, or Defender
Was this activity expected in the lab or environment?	Helps separate valid testing from suspicious behavior
Does this event map to a known MITRE ATT&CK technique?	Provides threat-informed context
Are there related alerts from the same host?	Helps identify attack chains
Did the event occur during an approved maintenance or testing window?	Helps identify false positives
Does the command or process appear suspicious?	Supports escalation decision
Is containment or further investigation required?	Determines response action

These questions help the analyst avoid making assumptions and encourage evidence-based triage.

4. Triage Severity Model

For this lab project, alert severity should be interpreted based on both rule severity and investigation context. A detection may be high-value, but it may not always indicate malicious activity if it was generated by approved lab testing.

Severity	Meaning	Example
Informational	Expected lab or testing activity	Atomic Red Team run during approved validation
Low	Suspicious but likely expected	EICAR test file created in known lab folder
Medium	Suspicious activity requiring review	Encoded PowerShell executed by an admin account
High	Strong suspicious behavior	Unexpected local user account creation
Critical	Multiple related alerts suggesting compromise	Encoded PowerShell followed by account creation and service persistence

Severity should not be based only on the rule ID. It should be based on context, user behavior, host role, command line, timing, and related events.

DET-001: PowerShell Encoded Command Execution

Detection Overview

This detection identifies PowerShell encoded command execution on a Windows endpoint. PowerShell encoded commands use Base64 encoding to hide or compress command content. While this can be used legitimately by administrators and automation tools, attackers commonly use encoded PowerShell to make malicious activity harder to inspect.

Field	Value
Detection ID	DET-001
Detection Name	PowerShell Encoded Command Execution
Custom Rule ID	100100

MITRE ATT&CK Technique	T1059.001
Tactic	Execution
Log Source	Sysmon / Windows Process Telemetry
Primary Evidence	Wazuh alert, command line, Sysmon process event

Initial Analyst Questions

The analyst should begin by asking:

Question	Purpose
Which user executed PowerShell?	Determines whether the account had a legitimate reason
What was the full command line?	Identifies encoded command usage
What was the parent process?	Determines whether PowerShell was launched normally or suspiciously
Was the command run interactively or by another process?	Helps identify automation or malicious process chains
Can the encoded command be decoded?	Reveals the actual command content
Was this part of approved lab testing?	Separates validation activity from suspicious activity
Are there other alerts from the same host?	Helps identify attack sequence

Key Fields to Review in Wazuh

When reviewing the alert in Wazuh Dashboard, the analyst should inspect the alert details and JSON fields.

Important fields include:

Field	Why It Matters
<code>rule.id</code>	Confirms custom detection rule 100100 fired
<code>agent.name</code>	Identifies the Windows endpoint
<code>agent.ip</code>	Identifies the endpoint network address
<code>win.system.channel</code>	Confirms the Windows event source
<code>win.system.eventID</code>	Confirms the event type
<code>win.eventdata.image</code>	Shows the executable path, usually PowerShell
<code>win.eventdata.commandLine</code>	Shows the encoded command
<code>win.eventdata.parentImage</code>	Shows the parent process
<code>win.eventdata.user</code>	Shows the account that executed the command
<code>rule.mitre.id</code>	Confirms MITRE mapping to T1059.001

SOC Triage Steps

The analyst should follow these steps:

1. Open the Wazuh alert and confirm that rule `100100` fired.
2. Confirm that the alert relates to PowerShell execution.
3. Review the full command line and look for `-EncodedCommand`, `-enc`, or similar encoded execution parameters.
4. Identify the user account that executed the command.
5. Review the parent process. A normal parent may be `explorer.exe` or a terminal process. A suspicious parent may be an Office application, browser, script host, or unknown executable.
6. Decode the Base64 command if possible.

7. Review whether the decoded command performs normal activity or suspicious actions such as downloading files, disabling defenses, modifying registry keys, or executing additional payloads.
8. Search Wazuh for additional alerts from the same endpoint within 10–30 minutes before and after the event.
9. Check whether the event was part of approved testing.
10. Decide whether to close as lab activity, document as suspicious, or escalate.

False-Positive Review

Possible legitimate causes include:

- IT automation scripts
- Software deployment tools
- Endpoint management tools
- Login scripts
- Administrator troubleshooting
- Lab validation activity

However, encoded PowerShell should still be reviewed carefully. The presence of encoding does not automatically mean malicious activity, but it does increase the need for command-line analysis.

Escalation Criteria

Escalate this alert if:

- The encoded command cannot be explained.
- The user account is not expected to run PowerShell.
- The parent process is suspicious, such as Word, Excel, Outlook, browser, or unknown executable.
- The decoded command downloads or executes remote content.
- The command disables security controls.
- The event is followed by account creation, service creation, scheduled tasks, or Defender alerts.
- Similar encoded PowerShell activity appears across multiple endpoints.

Recommended Analyst Action

If confirmed as authorized lab activity, document the alert as validated detection evidence. If observed in a real environment and not approved, escalate to incident investigation, preserve the command line, decode the payload, and search for related activity on the host.

DET-002: Local User Account Creation

Detection Overview

This detection identifies local user account creation on a Windows endpoint. Local account creation may be legitimate during administration, but attackers can also create local accounts to maintain access after compromise.

Field	Value
Detection ID	DET-002
Detection Name	Local User Account Creation
Custom Rule ID	100101
MITRE ATT&CK Technique	T1136.001
Tactic	Persistence
Log Source	Windows Security Logs
Primary Evidence	Wazuh alert, account creation event, username fields

Initial Analyst Questions

The analyst should ask:

Question	Purpose
What account was created?	Identifies the new account
Who created the account?	Identifies the actor
Was the account created locally or through domain activity?	Determines scope

Was the account added to privileged groups?	Checks for privilege escalation
Did the account log in after creation?	Identifies possible persistence use
Was this account creation approved?	Determines legitimacy
Does the username look suspicious?	Detects attacker-created accounts

Key Fields to Review in Wazuh

Important fields include:

Field	Why It Matters
<code>rule.id</code>	Confirms custom rule 100101 fired
<code>agent.name</code>	Identifies affected endpoint
<code>win.system.eventID</code>	Confirms account creation event
<code>win.eventdata.targetUserName</code>	Shows the created account
<code>win.eventdata.subjectUserName</code>	Shows who created the account
<code>win.eventdata.subjectDomainName</code>	Shows account domain context
<code>win.eventdata.targetSid</code>	Identifies the new account SID
<code>rule.mitre.id</code>	Confirms mapping to T1136.001

SOC Triage Steps

The analyst should follow these steps:

1. Open the Wazuh alert and confirm rule `100101`.
2. Identify the newly created account name.
3. Identify the account that performed the creation.

4. Check whether the creator account is an administrator, helpdesk account, system account, or unknown user.
5. Review whether the new account name appears suspicious, generic, hidden, misspelled, or similar to a legitimate admin account.
6. Search for group membership changes after the account creation.
7. Check whether the account was added to the local Administrators group.
8. Search for logon events involving the new account.
9. Review related alerts from the same endpoint.
10. Confirm whether this was expected maintenance or lab testing.
11. If unauthorized, escalate for account review and endpoint investigation.

False-Positive Review

Possible legitimate causes include:

- Helpdesk troubleshooting
- Local administrator account setup
- Temporary lab user creation
- System imaging or deployment process
- IT maintenance

Even if legitimate, local account creation should be documented because it changes the security state of the endpoint.

Escalation Criteria

Escalate this alert if:

- The account was created by an unexpected user.
- The username appears suspicious.
- The account was added to privileged groups.
- The account logged in shortly after creation.
- Account creation follows suspicious PowerShell or service activity.
- The account was created outside business hours or outside maintenance windows.
- The endpoint is a sensitive system.

Recommended Analyst Action

If this is lab activity, document the detection and confirm cleanup of the test account. If this is a real environment and unauthorized, disable the account, preserve logs, review group membership, investigate the creator account, and search for related persistence activity.

DET-003: Windows Service Creation / Modification

Detection Overview

This detection identifies Windows service creation or modification activity. Windows services are commonly used by legitimate software, drivers, and management tools. However, attackers can abuse Windows services to maintain persistence or execute commands with elevated privileges.

Field	Value
Detection ID	DET-003
Detection Name	Windows Service Creation / Modification
Custom Rule ID	100102
MITRE ATT&CK Technique	T1543.003
Tactic	Persistence / Privilege Escalation
Log Source	Windows Service / Process Telemetry
Primary Evidence	Wazuh alert, service name, binary path, command line

Initial Analyst Questions

The analyst should ask:

Question	Purpose
What service was created or modified?	Identifies the affected service
What binary path does the service use?	Determines what will execute
Who created or modified the service?	Identifies the actor
Was the service started?	Determines whether execution occurred
Is the binary path suspicious?	Helps identify malicious persistence

Was software installed around the same time?	Checks for legitimate cause
Is the service name randomly generated or misleading?	Detects attacker tradecraft

Key Fields to Review in Wazuh

Important fields include:

Field	Why It Matters
<code>rule.id</code>	Confirms custom rule 100102 fired
<code>agent.name</code>	Identifies affected endpoint
<code>win.system.eventID</code>	Confirms service event
<code>win.eventdata.serviceName</code>	Shows the created or modified service
<code>win.eventdata.imagePath</code>	Shows the service binary path
<code>win.eventdata.accountName</code>	Shows account associated with service
<code>win.eventdata.commandLine</code>	Shows command used to create the service
<code>win.eventdata.parentImage</code>	Shows process that launched service creation
<code>rule.mitre.id</code>	Confirms mapping to T1543.003

SOC Triage Steps

The analyst should follow these steps:

1. Open the Wazuh alert and confirm rule **100102**.
2. Identify the service name.
3. Review the service binary path.
4. Determine whether the service path points to a legitimate software directory or suspicious location such as Temp, Public, AppData, or user profile folders.
5. Identify the user or process that created the service.
6. Check whether the service was started.
7. Review nearby process creation events.
8. Search for the same service name across other endpoints.
9. Check whether software installation, driver update, or endpoint management activity occurred at the same time.
10. Determine whether the event is expected or suspicious.
11. Escalate if the service appears unauthorized or malicious.

False-Positive Review

Possible legitimate causes include:

- Software installation
- Driver installation
- Security agent updates
- Endpoint management tools
- Windows updates
- IT maintenance

Service creation is common, so context matters. The detection becomes more suspicious when the service name is unusual, the binary path is suspicious, or the creator process is unexpected.

Escalation Criteria

Escalate this alert if:

- The service binary path points to Temp, Public, AppData, Downloads, or another user-writable directory.
- The service name is random, misleading, or similar to a legitimate Windows service.
- The service was created by a suspicious process.
- The service was created after PowerShell encoded command execution.
- The service starts automatically.
- The service binary is unsigned or unknown.
- There is no approved change or installation activity.

Recommended Analyst Action

If confirmed as lab testing, document the alert and confirm the test service was removed. If suspicious in a real environment, stop the service if appropriate, preserve the binary, collect hashes, review persistence mechanisms, and escalate for incident response.

DET-009: EICAR Malware-Test File Detection

Detection Overview

This detection identifies Windows Defender detection or remediation of the EICAR malware-test file. EICAR is a safe anti-malware test file used to validate antivirus detection and telemetry forwarding. It is not real malware, but it is designed to trigger antivirus products.

Field	Value
Detection ID	DET-009
Detection Name	EICAR Malware-Test File Detection
Custom Rule ID	100108
MITRE ATT&CK Technique	T1204.002
Tactic	Execution
Log Source	Windows Defender Operational Logs
Primary Evidence	Defender event, Wazuh alert, threat name, file path

Initial Analyst Questions

The analyst should ask:

Question	Purpose
Was EICAR testing expected?	Determines whether this is approved validation
Which user created or downloaded the file?	Identifies actor
What file path triggered Defender?	Identifies location
What action did Defender take?	Determines whether remediation occurred
Did Wazuh receive the Defender event?	Confirms telemetry pipeline
Are there other Defender alerts on the same host?	Checks for broader malware activity
Is this a lab host or production host?	Determines risk level

Key Fields to Review in Wazuh

Important fields include:

Field	Why It Matters
<code>rule.id</code>	Confirms custom rule 100108 fired
<code>agent.name</code>	Identifies affected endpoint
<code>win.system.channel</code>	Confirms Defender Operational log source
<code>win.system.eventID</code>	Confirms Defender detection/remediation event
<code>win.eventdata.threatName</code>	Shows detected threat name
<code>win.eventdata.path</code>	Shows file path
<code>win.eventdata.severityName</code>	Shows Defender severity

`win.eventdata.actionName` Shows remediation action

`rule.mitre.id` Confirms mapping to T1204.002

SOC Triage Steps

The analyst should follow these steps:

1. Open the Wazuh alert and confirm rule `100108`.
2. Confirm that the event came from Windows Defender Operational logs.
3. Review the threat name and confirm whether it is EICAR.
4. Review the file path where the test file was created or detected.
5. Identify the user account associated with the activity.
6. Confirm the Defender action, such as detected, quarantined, removed, or remediated.
7. Search for additional Defender alerts from the same endpoint.
8. Confirm whether the host is part of an approved lab or validation exercise.
9. If this is expected lab activity, document the detection as validated.
10. If this appears in a production environment unexpectedly, investigate further.

False-Positive Review

For this project, EICAR is expected test activity. In a production environment, EICAR may still appear during security validation or antivirus testing.

Possible legitimate causes include:

- Antivirus testing
- SOC validation
- Purple-team exercise
- Endpoint onboarding validation
- Lab demonstration

However, analysts should not ignore Defender alerts simply because EICAR is safe. The key question is whether the activity was authorized.

Escalation Criteria

Escalate this alert if:

- EICAR appears on a production endpoint without approval.
- The detection is not from a known testing host.

- Multiple Defender detections appear around the same time.
- The threat name is not EICAR.
- Defender failed to remediate the file.
- The file appeared in a suspicious directory.
- The activity was performed by an unexpected user.

Recommended Analyst Action

If confirmed as approved testing, close the alert as expected validation activity and document the evidence. If unexpected, verify whether the file is truly EICAR, review user activity, check Defender history, and search for additional malware detections.

DET-010: Atomic Red Team Framework Activity

Detection Overview

This detection identifies Atomic Red Team framework activity on a Windows endpoint. Atomic Red Team is a legitimate adversary-emulation framework used by blue teams, purple teams, and detection engineers to validate security controls against MITRE ATT&CK techniques.

Although Atomic Red Team is legitimate, unexpected execution outside an approved test window may be suspicious.

Field	Value
Detection ID	DET-010
Detection Name	Atomic Red Team Framework Activity
Custom Rule ID	100109
MITRE ATT&CK Technique	T1059.001
Tactic	Execution
Log Source	Sysmon Event ID 1
Primary Evidence	Sysmon process event, command line, Wazuh alert

Initial Analyst Questions

The analyst should ask:

Question	Purpose
Was Atomic Red Team testing approved?	Determines whether the activity is expected
Which user executed the command?	Identifies actor
Which host generated the alert?	Identifies endpoint
What technique was referenced?	Identifies ATT&CK behavior being tested
Was the command run in a lab or production environment?	Determines risk
Were additional Atomic tests executed?	Identifies scope
Did the command execute payloads or only display details?	Determines impact

Key Fields to Review in Wazuh

Important fields include:

Field	Why It Matters
<code>rule.id</code>	Confirms custom rule 100109 fired
<code>agent.name</code>	Identifies affected endpoint
<code>win.system.channel</code>	Confirms Sysmon source
<code>win.system.eventID</code>	Confirms process creation event
<code>win.eventdata.image</code>	Shows PowerShell or related executable
<code>win.eventdata.commandLine</code>	Shows Atomic Red Team command

<code>win.eventdata.parent</code>	Shows parent process
<code>Image</code>	
<code>win.eventdata.user</code>	Shows executing user
<code>rule.mitre.id</code>	Confirms mapping to T1059.001

SOC Triage Steps

The analyst should follow these steps:

1. Open the Wazuh alert and confirm rule `100109`.
2. Confirm that the event came from Sysmon Event ID 1.
3. Review the command line for Atomic Red Team keywords such as `Invoke-AtomicTest`, `AtomicRedTeam`, or technique IDs.
4. Identify the user account that executed the command.
5. Identify the host where the command was executed.
6. Determine whether the host is an approved testing or lab system.
7. Determine whether the test used `-ShowDetailsBrief` or executed an actual atomic test.
8. Search for additional alerts from the same host and user.
9. Confirm whether testing was approved.
10. If approved, document as validation activity. If not approved, escalate for investigation.

False-Positive Review

Possible legitimate causes include:

- Detection engineering tests
- Purple-team exercises
- SOC validation work
- Cybersecurity training labs
- Approved internal testing

Atomic Red Team usage should not automatically be treated as malicious, but it should be controlled. In production environments, it should only be used by approved users during approved testing windows.

Escalation Criteria

Escalate this alert if:

- Atomic Red Team was executed by an unauthorized user.
- The activity occurred on a production endpoint.
- The activity happened outside an approved testing window.
- Actual atomic tests were executed without approval.
- The command triggered additional suspicious alerts.
- The host shows other signs of compromise.
- The user account is not part of a security testing team.

Recommended Analyst Action

If this was approved lab activity, document the alert as successful detection validation. If unexpected, investigate the user account, review PowerShell history where available, search for additional process execution events, and determine whether the endpoint was used for unauthorized testing or malicious activity.

Cross-Detection Correlation

While each detection can be reviewed individually, the strongest SOC analysis comes from correlation. Multiple alerts from the same host within a short period may indicate an attack chain.

Examples of concerning alert combinations include:

Alert Combination	Possible Interpretation
DET-001 + DET-002	PowerShell execution followed by account persistence
DET-001 + DET-003	PowerShell execution followed by service persistence
DET-002 + DET-003	Account creation followed by service creation
DET-009 + other suspicious alerts	Malware detection with possible follow-on activity
DET-010 + multiple endpoint alerts	Atomic testing or unauthorized adversary emulation

In this lab, these combinations may be expected because controlled tests were performed. In a real environment, the same combinations would require deeper investigation.

Alert Closure Criteria

An alert can be closed as expected or benign when:

- The activity was part of approved lab testing.
- The user account is known and authorized.
- The command matches documented test commands.
- The affected endpoint is a lab system.
- No related suspicious activity exists.
- Cleanup was completed where required.
- Evidence was captured and documented.

An alert should remain open or be escalated when:

- The user is unknown or unauthorized.
- The command is suspicious or unexplained.
- The activity occurred on a production system.
- The alert is part of a larger chain.
- The detection involves persistence or malware telemetry.
- There are multiple related alerts from the same endpoint.

Recommended Evidence to Preserve

For each alert, the analyst should preserve:

Evidence Type	Purpose
Wazuh alert screenshot	Proves the detection fired
JSON alert details	Shows raw event fields
Command used for testing	Proves how telemetry was generated
MITRE mapping screenshot	Shows threat technique alignment
Timestamp	Supports investigation timeline
Hostname and user fields	Supports scoping
Cleanup evidence	Shows test artifacts were removed

For public documentation, evidence should be sanitized before publishing.

Final Analyst Notes

This triage guide demonstrates how alerts generated in the Windows Detection Engineering Lab should be investigated from a SOC perspective. Each detection includes not only the alert condition, but also the analyst questions, investigation steps, false-positive considerations, escalation criteria, and recommended response actions.